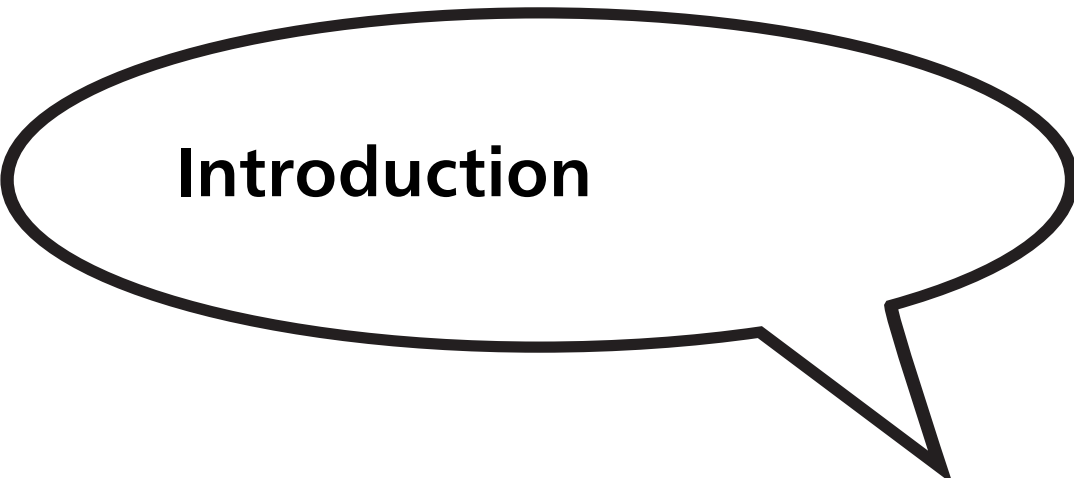




Introduction

The purpose of this introductory chapter is to lay the foundation for the rest of this book. This chapter is a bit more academic than the rest of the book, but it is important that we all use a common language when discussing terms such as moral, ethical, culture, law, and policy. These concepts are crucial to being able to assess right, wrong, and due diligence. A quote from the movie Ghostbusters is an excellent introduction to ethics in information technology (IT):

Dr. Egon Spengler: Don't cross the streams.

Dr. Peter Venkman: Why?

Dr. Egon Spengler: It would be bad.

Dr. Peter Venkman: I'm fuzzy on the whole good/bad thing. What do you mean "bad"?

Dr. Egon Spengler: Try to imagine all life as you know it stopping instantaneously, and every molecule in your body exploding at the speed of light.

Bill Murray's character, Dr. Venkman, is fuzzy on the whole good/bad thing and thus is in good company with most workers in information technology. Or is that wrong?

There was a movement towards "moral relativism" in the late 1990s (i.e., you do what is right for you and I will do what is right for me). Moral relativism is still taught in colleges and universities, but it will rapidly get you fired in the workplace. The most important thing we learned as we worked on this book was that people and organizations have a strong sense of right and wrong. This is not to say they will not do wrong, but that they know they are doing wrong. The most striking thing about the real-life issues discussed in this book is how many of the people were fired or disciplined when they were caught.

Information technology, computers, and networks do not raise new ethical issues; stealing is still stealing and stalking is still stalking. However, the Internet does contribute a fascinating sense of anonymity; the notion that no one can see or find out what we are doing.

When people think of ethics, they often think of *personal values*. While they are a large part of ethics, because of the rapid advancement of information technology, a redefinition of ethics must occur that includes the non-human element and what it represents—the computer. The purpose of ethics in information security is not just philosophically important, it can mean the survival of a business or an industry. Dr. Venkman may have been fuzzy on the whole good bad thing, but after Dr. Spengler explained the effects of protonic reversal, Dr. Venkman was able to mentally file crossing the streams in the "bad" category. The principle of deterrence is applicable to the workplace (i.e., repercussions have an impact on our sense of ethics).

Our actions and choices regarding computers will probably not result in all life as we know it stopping instantaneously, but ethical lapses can still have a disastrous effect. A perfect example of this is Enron. Enron went from being a visionary corporation to the butt of jokes throughout corporate America.

The ethical failure of Enron and their auditors' ethics created such a disaster that the damage extended far beyond the demise of Enron and Andersen. Consider the following quote.

"My name is Frank Nusspickel and I'm a New York, CPA, an audit partner with the New York City office of Andersen, LLP, and a former President of the New York Society of CPA's. I am here today because faith in my firm and the accounting profession, and in the integrity of the capital markets system has been shaken."

*TESTIMONY OF ANDERSEN, LLP BEFORE THE NEW YORK STATE
SENATE HIGHER EDUCATION COMMITTEE KENNETH P. LaVALLE,
CHAIRMAN*

In the end, the auditors lost respect, prestige, money, and business opportunities. Those of us in IT and, even more importantly, in information security, should learn volumes from that event. However, even though we as a community have some deep uneasy feeling that all is not well, we, like Dr. Venkman, are fuzzy on that whole good/bad thing. This book's goal is to take the fuzz out of good and bad across hundreds of IT-related issues. We do it with many people's opinions and stories. We approach most issues with both a conservative and a liberal view and summarize by showing the path of wisdom. This will help you in your management decisions and policy development so you can identify the times to go against what is expedient or expected in order to maintain your core values. A strong ethical environment is part of the formula for corporate success; ethics is business smarts.

Before diving into the countless interesting and diverse ethical issues that arise in the workplace, we must first discuss five related concepts that come to play in determining one's action in response to any situation. These concepts are *ethics, morals, policy, law, and culture*.

At the individual level, our ethics are based on our personally accepted principles. There is also the notion of a corporate set of ethics. A company has a general sense of ethics that drives the policies it sets. This ethics stems from the company founders and develops over time. Companies have a reputation in the industry for being loose and fast or old and stodgy, a reputation that corresponds to their sense of corporate ethics.

Morals are accepted from an authority, usually cultural or religious. Today, morals are conceived around six dominant religious thoughts: Buddhism, Christianity, Hindu, Islam, Judaism, and Moral Relativism. However, there are a thousand shades of grey for each of these primary categories.

Corporate policy provides the framework in which a company's employees are to act in response to various situations. Ideally, policies are derived from the corporate *Mission Statement*. The company then creates a top-level policy that is broad but sets the tone for issue-specific policies. In addition to the several written policies companies have, such as a Non-Compete Agreement and Standards of Business Conduct, there are the conventions and modes of behavior often referred to as the *Corporate Culture*.

Companies and organizations operate under a variety of local and national laws. Law is a separate matter from ethics; however, the two often overlap. Some laws are so widely agreed upon that they reflect sound ethics, such as the law against child pornography. At the other end of the spectrum there are laws that are routinely ignored such as speed limits on freeways where ethics are not compromised by not obeying the law.

Sometimes law and ethics are in opposition. Two examples from U.S. history are the Black Codes that defined the freed African Americans as legally subordinate, and the Jim Crow laws that imposed racial segregation primarily in the southeast. They were laws, but there is no way they can be considered ethical. Further, if one could save a life by breaking a law, one might be morally justified to do so.

When we consider great ethical lapses (Enron or the Klu Klux Klan), we realize that it requires an enormous investment to believe that something so wrong is okay. These obviously wrong belief systems make an impact that lasts generations and are always negative and always result in lost productivity and profit.

Stealing is generally considered morally wrong; the Bible, Koran, and Torah all agree on this. It is typically against the law and considered unethical. So how can peer-to-peer networking for downloading copyrighted music, movies, and books be okay?



@#&!?!

I Was a Victim

Sometimes there is a tendency to consider this type of theft a victimless crime. The day I found Network Intrusion Detection 3rd Edition available on the Internet I was just sick to my stomach. Judy Novak and I worked for months on that book. If you have ever come back home to your apartment or home and found it robbed, then you know exactly how I felt. I hope two people read this book: the employee at Pearson Publishing who committed the error of judgment that allowed a .pdf of our book to end up in the wild, and the low life that is serving it up for others to steal.

Stephen Northcutt

The law can provide deterrence against abandoning a reasonable sense of ethics or morals and simply choosing to do whatever we please. People may consider downloading music to be their right; however, it is an illegal act. The law is being enforced and for some, the penalty costs are too high. In this case, the law would validly supercede the ethics. The recording industry is doing a very credible job of using the law as a deterrence.

Finally, we consider culture; a mixture of norms, standards, and expectations for members of a community. In terms of ethics in IT, we have four types of cultures to consider: *corporate culture*, *nations or people groups*, *globalization*, and *Internet culture*.

Corporate culture is a result of expectations and standards that reflect the ethics of an organization and is often reflected in corporate policy. To evaluate the ethics of an organization we look for three things: *formal ethics*, *informal ethics*, and *ethics leadership*.

Formal ethics opinions or perceptions are often published. They include items such as a code of ethics or an ethics policy, as well as issue-specific guidance. If you were to enter “formal ethics opinions” into google, you would find examples especially for trusted professionals such as lawyers or certified public accountants (CPAs). Most organizations have not completed a formal ethics statement or policy, though it is certainly a good idea. We have included a sample one as a sidebar in this chapter that you can download an electronic version from: www.sans.org/resources/policies/

In the spirit of “tastes great, less filling,” different camps have different views about the exact definition of informal ethics guidance or perceptions. One explanation is material that has not received the same level of consensus or rigorous testing as formal ethics. The Sidebar “Dispensing Legal Advice over the Internet” gives you the feeling of a published informal ethic.



Legal Advice over the Internet

Is it proper to deliver professional advice directly to consumers via the Internet?

A number of legal help services have sprouted on the World Wide Web, where a consumer can ask a general question of a lawyer. Sometimes fees are charged and sometimes the advice is free. An example is: www.freeadvice.com.

Oftentimes the people operating these sites do not wish for their content to constitute specific legal advice in an attorney-client relationship for any of three reasons:

1. An attorney dispensing legal advice to true legal clients owes ethical duties of confidentiality, loyalty, and diligence, and the presence of those duties would make the Web service more rigid and expensive.
2. Often, these Web sites are owned and operated at least in part by non-lawyers, and any lawyers who are contributing to the sites will have an ethical duty not to split legal fees with non-lawyers.
3. Sometimes the people operating or providing content through the sites are non-lawyers and state ethics laws prohibit non-lawyers from practicing law. The laws behind each of these three reasons are intended to protect consumers of legal services.

In order to avoid classifying their content as specific legal advice creating an attorney-client relationship, the Q&A Web sites usually post disclaimers and try to make their answers generic.

Interestingly, when legal question and answer shows were first broadcast over radio in the 1930s, local bar associations took action, in the name of professional ethics, to shut the shows down, claiming they were a threat to unsophisticated consumers. The fear was that consumers would not understand the information delivered through the shows and mistakenly believe their legal problems were simpler than was actually the case.

The modern version of the Q&A radio show is the Q&A Web site. But today is not the 1930s. Even though the Q&A Web phenomenon has been the subject of considerable discussion by bar associations, no one is taking action against the Web sites. An important reason is that people

Continued

perceive the profession would lose if it tried to shut down the sites today. That perception is supported by the recent experience in Texas, where the profession tried to drive out publishers of legal how-to manuals and software, but was roundly rebuffed by the legislature.

The trend in this area of law seems to be leniency and support for innovative sources of legal information for consumers.

*Benjamin Wright
Chief Legal Counsel
PestPatrol.com*

Another explanation for an informal ethic would be to describe a body of information that is either not written down or poorly documented, but that nevertheless is consistently and powerfully held in an organization. We will try to illustrate this concept with an anecdote.



@#&!?!

We don't Party Hearty

When I attended my first SANS conference in 1995, there was a tendency for some people to treat it as a party experience. There were only two SANS conferences a year and it was a chance to meet long lost friends. There were activities like "beer brewing BOFs." There were some great stories, especially from New Orleans, about flamboyant discretions committed by the top names in technical information security. In 2000 as the GIAC Certification series was unveiled and the level of technical intensity started to climb, the culture began to rapidly change. No written memo was ever issued that stated drinking your brains out was against the rules, but the old party hearty instructors began to disappear at an amazing rate. Today only two of the instructors from before year 2000 survive and continue to teach and they fully understand the importance of discretion.

Stephen Northcutt

This anecdote is an example of an informal ethic as it seems to apply in the IT world. In the 1990s, a behavior was considered cool and part of being accepted by the culture. In the year 2000 and beyond, it was a ticket to termination. The period of change was very painful for a number of people.



Discrepancy is Expensive

Anytime there is a difference between a formerly perceived and understood informal ethic there will be costs to the organization in terms of job turnover, job satisfaction and commitment decrease. Anytime there is a difference between a formal ethic, and a corresponding informal ethic, the same problems will occur.

Stephen Northcutt

We have discussed formal and informal ethics; we should now consider ethical leadership. Just because you are a vice president or a CEO does not mean you are a leader in terms of either positive or negative ethics in your organization. This is a very important concept. To understand the concept fully, we ask people to think back on their high school experience. You were probably primarily associated with a group that mostly could be defined by either positive or negative ethics.

If the people you spent the majority of your time with drove cars very fast, were fixated on getting someone to buy them beer, were into drugs, were focused on sex even at the risk of pregnancy or disease, then that might show a negative ethical bent. There were a number of examples of ethical leadership in such a group. One or two people were the top dog. There was the pretty girl that kept falling for Mr. Wrong, a bad individual and a negative ethical leader. If you fast-forward to the maturity level of today from high school, you have a pretty good idea of the profile negative ethical leaders exhibit.

If the people you spent the majority of your time with were in service clubs, were fixated on grades, were into student government if they could take the time away from being an Eagle scout, were focused on sex, but virginity was a legitimate option, then that might be an indicator of a positive ethical bent. There were a number of examples of ethical leadership in such a group. One or two people in such a group typically are accepted to an Ivy League school and achieve significant success.

Most of us fall between the extremes. We hope the proceeding two paragraphs help you begin to think about the positive and negative ethical leaders in your organization. Of course, these two examples are simplistic. They do not take

into account gossip, intentional dissention, race, creed, and culture issues, financial status, the evil clerk syndrome, or the overbearing or obnoxious boss. When we evaluate organizations, we find that if we can identify the major players in terms of the formal and informal ethical position of the organization, and then interview those players about their high school experience and how they presently view the world, it gives us a powerful model to understand the forces they exert on the organization.

In addition to the actual human leaders, there is a thought leadership component to ethical leadership. Ben and Jerry's is a good example. The company leaders have a positive ethical leadership style and the company, especially five years or so ago, reflected this leadership style right down to the mission statement element of informed prosperity. In general, an organization with positive ethical leadership both at the senior management and second level management will prosper.

In contrast, there is the example of Foundstone and NT Objectives. Only the sources close to both companies will ever know for sure what went on, but from the reports in the trade press there were numerous examples of negative ethical leadership. After a breakup between the two companies, a number of press articles claimed widespread copyright infringement at Foundstone. The leaders of both companies were dragged through the mud with claims that they were dishonest and difficult to deal with. We have met and done business with both individuals and find it hard to believe any of the claims. However, one thing is certain, there were leaders of negative ethics somewhere in both groups.

One link that discusses the situation in a fairly balanced fashion is found at: www.varbusiness.com/components/Nl/Insider/article.asp?ArticleID=43015

Formal Ethics Statement

<Company Name> Ethics Policy

1. **Overview** <Company Name> purpose for this ethics policy is to establish a culture of openness, trust, and integrity in business practices. Effective ethics is a team effort involving the participation and support of every <Company Name> employee. All employees should familiarize themselves with the ethics guidelines that follow this introduction.

<Company Name> is committed to protecting employees, partners, vendors, and the company from illegal or damaging actions by individuals, either knowingly or unknowingly. When

Continued

<Company Name> addresses issues proactively and uses correct judgment, it will help set us apart from competitors.

<Company Name> will not tolerate any wrongdoing or impropriety at anytime. <Company name> will take the appropriate measures and act quickly in correcting the issue if the ethical code is broken. Any infractions of this code of ethics will not be tolerated.

2. **Purpose** Our purpose for authoring a publication on ethics is to emphasize the employee's and consumer's expectation to be treated to fair business practices. This policy will serve to guide business behavior to ensure ethical conduct.
3. **Scope** This policy applies to employees, contractors, consultants, temporaries, and other workers at <Company Name>, including all personnel affiliated with third parties.
4. **Policy**
 - Executive Commitment to Ethics
 - Top brass within <Company Name> must set a prime example. In any business practice, honesty and integrity must be top priority for executives.
 - Executives must have an open door policy and welcome suggestions and concerns from employees. This will allow employees to feel comfortable discussing any issues and will alert executives to concerns within the work force.
 - Executives must disclose any conflicts of interest regarding their position within <Company Name>.
 - Employee Commitment to Ethics
 - <Company Name> employees will treat everyone fairly, have mutual respect, promote a team environment, and avoid the intent and appearance of unethical or compromising practices.
 - Every employee needs to apply effort and intelligence in maintaining ethics value.
 - Employees must disclose any conflict of interests regarding their position within <Company Name>.
 - Employees will help <Company Name> to increase customer and vendor satisfaction by providing quality products and timely responses to inquiries.

Continued

- Company Awareness
 - Promotion of ethical conduct within interpersonal communications of employees will be rewarded.
 - <Company Name> will promote a trustworthy and honest atmosphere to reinforce the vision of ethics within the company.
- Maintaining Ethical Practices
 - <Company Name> will reinforce the importance of the integrity message and the tone will start at the top. Every employee, manager, and director needs to consistently maintain an ethical stance and support ethical behavior.
 - Employees at <Company Name> should encourage open dialogue, get honest feedback, and treat everyone fairly, with honesty and objectivity.
 - <Company Name> has established a best practice disclosure committee to make sure the ethical code is delivered to all employees and that concerns regarding the code can be addressed.
- Unethical Behavior
 - <Company Name> will avoid the intent and appearance of unethical or compromising practice in relationships, actions, and communications.
 - <Company Name> will not tolerate harassment or discrimination.
 - Unauthorized use of company trade secrets and marketing, operational, personnel, financial, source code, and technical information integral to the success of our company will not be tolerated.
 - <Company Name> will not permit impropriety at any time and we will act ethically and responsibly in accordance with laws.
 - <Company Name> employees will not use corporate assets or business relationships for personal use or gain.

5. Enforcement

- Any infractions of this code of ethics will not be tolerated and <Company Name> will act quickly in correcting the issue if the ethical code is broken.

Continued

- Any employee found to have violated this policy may be subject to disciplinary action, up to and including termination of employment

The difference in culture between two organizations can be startling. Imagine leaving government service after 25 years to take a job at a major Wall Street player. All of a sudden you would be expected to move much faster than before, dress better, be alert, quick on the uptake, fast on your feet, and hungry to take advantage of an opportunity. After 25 years of being told to slow down, you would suddenly be aware of a need to go faster. Most people cannot handle a shift in culture that significant.



@#&!?!

Cisco and Drug Tests

Note: This is a third-hand story and I only know the government side of it. If you have first-hand information and are willing to share documented information for this example, that would be wonderful!

Corporate culture literally drives the critical policy decisions an organization makes. When I was a researcher at a U.S. Navy lab, there was an interaction between the U.S. government and Cisco. The government was arguing that if they were going to buy Cisco routers, then Cisco needed to implement drug testing. Cisco declined. I was speaking with a senior government official who was implying that Cisco would not implement the drug tests because they had something to hide. Fortunately, the government wisely backed down or they would have been forced to do without Sun Microsystems as well, which has also never done drug testing. Cisco's decision had nothing to do with a pro-drug use attitude. Cisco employees at this stage of company growth were highly motivated, almost to a maniacal degree. The company simply eschewed any unnecessary intrusion which might cause employees to take their eye off the ball. The policy decision was congruent with the management style and culture of Cisco at the time. They stuck to their guns and it was the government that blinked.

Stephen Northcutt

www.workforce.com/section/06/feature/23/53/63/

We have focused most of the culture discussion on corporate culture, since this book is focused on ethics in IT organizations. However, the culture of a nation or people group also affects ethics. This goes beyond the typical “ugly American” lack of politeness such as trying to establish service level agreements within a company or taking a business card with one hand in Japan. We will try to illustrate how differences in culture can actually make someone appear untrustworthy with an anecdote.



@#&!?!

Preachers in London

A California based conservative church named Calvary Chapel was expanding into the UK. A bunch of pastors from the U.S. flew to meet their counterparts in London, they met on a Sunday afternoon and went to lunch. The Brits ordered beer with lunch and the conservative Christians immediately began to have doubts they should be in their denomination. They had ordered coffee and the Brits were wondering the same thing about them as they reckoned Sunday was supposed to be a day of rest for that denomination.

Stephen Northcutt

Globalization is also a cultural force. Change tends to increase stress, hamper communication, and confuse organizational relationships. Clearly we are in a time of unparalleled change. People groups that have lived with a stable culture for hundreds of years or more are changing. The United Nations Education Scientific and Cultural Organization (UNESCO) is pursuing the notion of universal ethics, or more simply, the globalization of ethics. As we become more interconnected, this becomes more important.

The Internet is a major driver for globalization of culture, and we briefly consider it in terms of its own culture. In e-mail, there are expected norms, standards, and expectations. If you do not believe us, write ten friends with your cap key set on. You will be told you were shouting. Chat rooms have a particular set of expectations and even their own language. And we can easily make a case that this unique culture has ethical ramifications; how do you feel about spam? Would you feel that posting a personal e-mail expressing your love for a young male friend on a public newsgroup would be a violation of trust?

We have explained how we are using the terms ethics, morals, policy, law, and culture in this book. We discuss a wide variety of issues; many that actually happened to someone who felt the need to respond to the situation ethically. We explain the issue and then give a classic conservative and liberal response to it. Liberal and conservative do not imply a right way of thinking, nor do they correspond to political views. The best way to think of them is as guardrails to help keep you focused on the issue in light of your corporate culture. For example, a conservative corporate culture might assert an employee has no presumption of privacy. In such a conservative corporate culture, your e-mail or other transmissions might be monitored. A more liberal culture might choose to trust the employees and grant them a presumption to privacy.

Since the key is your own corporate culture, you will not always accept our summary answer. Also, please keep in mind that the Soapbox and Anecdote features were contributed by many people and may not represent the ethical positions of the author team.

The best way to use a book like this is to remember the *watermelon principle*. Eat the fruit, spit out the seeds, swallow what works for you in the context of your organization's culture, and move on. If an issue really makes you hot under the collar and you just have to speak to someone, contact the lead author, Stephen Northcutt, at Stephen@sans.org. You can be sure that while he may not agree with you, he will treasure your opinion as well as read and respond to your note.